

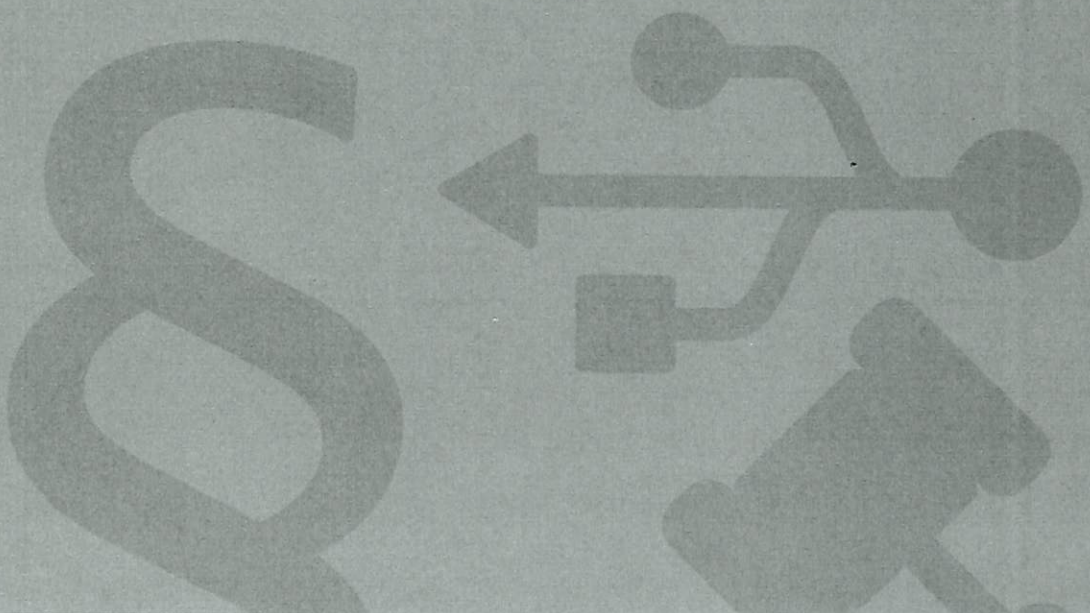


Redigeret af

Bettina Lemann Kristiansen

Digitalisering af retten

og det praktiske juridiske arbejde



- Bettina Lemann Kristiansen & Jørgen Dalberg-Larsen, *Lovene og livet. En rets-sociologisk grundbog*, 7. udg., Jurist- og Økonomforbundets Forlag 2022.
- Pernille Kræmmergaard, *Digital transformation: 10 evner din organisation skal mestre*, Djøf Forlag 2018.
- Sachin Kumar, Ajit Kumar Verma & Amna Mirza, "Historical Aspects of Technological Revolutions and Society Transformation", I: S. Kumar, A.K. Verma & A. Mirza (red.), *Digital Transformation, Artificial Intelligence and Society – Opportunities and Challenges*, Singapore 2024.
- Hanne Marie Motzfeldt, Jøren Ullits, Emilie Loiborg & Jens Kjellerup, *Fra forvaltningsjurist til udviklings- og driftsjurist. Retlige og dataetiske rammer for den digitale forvaltning*, 2. udg., Djøf Forlag 2024.
- Jesper Løffler Nielsen, *IT-retlige metaproblemer med retsplejen som praktisk studie*, Djøf Forlag 2017.
- Johan Næser, *Digitaliseringsklar lovgivning. En retlig analyse med fokus på retssikkerhed*, Djøf Forlag 2025.

KAPITEL 4

Indføring i databeskyttelsesretten

Kasper Bjerre Hendrup Andersen

1. Indledning

Formålet med dette kapitel er at give jurastuderende, jurister og praktikere en forståelig og grundlæggende indføring i databeskyttelsesretten. Dette søges opnået med afsæt i én samlet figur over de mest relevante bestemmelser i GDPR, der tager udgangspunkt i de databeskyttelsesretlige principper. Denne figurs samling af bestemmelserne i GDPR giver samtidig et struktureret indblik i de retlige relationer blandt regelsættets bestemmelser, som bidrager til den praktiske efterlevelse af GDPR.

GDPR omtales som '*the law of everything*' i den juridiske litteratur, fordi regelsættets anvendelsesområde er meget bredt defineret. Det betyder, at flere fysiske personer på den ene side opnår databeskyttelse, og at flere aktører på den anden side skal efterleve bestemmelserne i GDPR. Samtidig er GDPR udformet risikobaseret og teknologineutralt med henblik på at gøre det muligt at dæmme op for fremtidige trusler mod privatlivsbeskyttelsen afledt af den teknologiske udvikling. Dette behov for fremtidssikring af GDPR's bestemmelser har medvirket til vage og elastiske ordlyde. GDPR er derfor udformet på en sådan måde, at de færreste uden juridiske kompetencer har mulighed for at forstå, og især fortolke, regelsættet. Det betyder i praksis, at de aktører, som skal efterleve GDPR, har udfordringer med at forstå omfanget af deres pligter og i visse tilfælde vender 'det blinde øje' til på grund af den manglende retlige forståelse for databeskyttelse, hvilket jo modvirker GDPR's formål om at beskytte oplysninger om fysiske personer. Dermed kan det siges, at EU-lovgivers hensyntagen til digitalisering bl.a. har ført til en kompleks regulering (nærmest ufremkommelig for uindviede), som besværliggør det praktiske juridiske arbejde med at sikre databeskyttelse.

I det følgende fremstilles de relevante bestemmelser i GDPR i én over-

ordnet figur med henblik på at give en forståelig og grundlæggende indføring i databeskyttelsesretten for jurastuderende og praktikere.

2. Baggrunden for GDPR

I Danmark havde de fleste ikke fokus på databeskyttelse før 2018, hvor GDPR trådte i kraft. GDPR kan således opfattes som regulering af et nyt område, men dette er ikke tilfældet. I 1970 blev den første lov om databeskyttelse gennemført af den tyske delstat Hessen. Senere fulgte bl.a. nationale love i Tyskland, Danmark, Frankrig, Irland, Luxembourg, Holland og Storbritannien.

Denne brogede retsudvikling i EU var imidlertid en hindring for virkeliggørelsen af det indre europæiske marked, idet deling af personoplysninger på tværs af landegrænserne var besværlig og i visse tilfælde umulig, fordi de nationale lovgivninger havde forskelligt indhold, og fordi der i flere EU-lande ikke fandtes nogen specifik lovgivning på området. Selvom den teknologiske udvikling gjorde det nemmere at dele personoplysninger på tværs af landegrænser, var det på grund af de uens regler på området besværligt for virksomheder at handle med virksomheder etableret i andre EU-lande, fordi denne samhandel ofte indebar videregivelse eller overladelse af personoplysninger om kunder. En tilsvarende problematik ses for patientoplysninger i forskningsprojekter med aktører i forskellige EU-lande.

I 1995 vedtog Europa-Parlamentet og Rådet det europæiske databeskyttelsesdirektiv (direktiv 95/46/EF), som havde til formål at harmonisere databeskyttelsesretten i EU. Direktivformen overlod det imidlertid til det enkelte EU-land at bestemme form og midler for gennemførelsen af direktivets bestemmelser i national ret. Det havde den konsekvens, at direktivet blev implementeret forskelligt i EU, hvilket udfordrede formålet om harmonisering. Dette formål blev også udfordret af informationsteknologiens udvikling, som indebar øget indsamling og behandling af personoplysninger, og af globaliseringen af markeder og samarbejder.

Fragmenteringen af den måde, som beskyttelsen af personoplysninger var gennemført på i EU-lande, var uholdbar og ledte ifølge EU-Kommissionen til manglende retssikkerhed og en ulige beskyttelse af fysiske personer. Den brogede retstilstand var særligt problematisk, fordi retten til beskyttelse af personoplysninger i henhold til artikel 8 i EU-Charteret er en grundlæggende retssikkerhed, som derved kræver et ensartet beskyttelsesniveau i EU.

På den baggrund blev databeskyttelsen reguleret i en europæisk forordning (GDPR), hvor databeskyttelsesdirektivet samtidig blev ophævet. GDPR har to hovedformål. På den ene side sikrer GDPR den frie udveksling af personoplysninger i EU, hvorfor de enkelte lande ikke må opstille hindringer inden for det digitale indre marked. Det er i den forbindelse underordnet, om en dansk virksomhed handler med en dansk eller en europæisk virksomhed i relation til behandlingen af personoplysninger. På den anden side beskytter GDPR behandling af personoplysninger om fysiske personer for at sikre privatlivets fred og andre rettigheder.

3. GDPR og den danske databeskyttelseslov

Som nævnt ovenfor er GDPR en europæisk forordning. GDPR er derfor bindende i Danmark og derved en del af dansk ret (TEUF art. 288). EU-landene kunne imidlertid ikke nå til enighed om indholdet i GDPR. Kompromiset blev, at reguleringen af databeskyttelsen på flere punkter blev overladt til de enkelte EU-lande, og derfor kan GDPR ikke siges at være en sædvanlig forordning. Det skyldes, at den danske databeskyttelseslov indeholder supplerende bestemmelser. For eksempel særlovsreguleres aldersgrænsen for et barn og den tidsmæssige beskyttelse af afdødes personoplysninger i databeskyttelsesloven.

Fastlæggelse af databeskyttelsesretten i Danmark skal dermed ske i lyset af bestemmelserne i GDPR og den supplerende danske databeskyttelseslov. Således har fysiske personer ifølge GDPR en næsten ubetinget ret til indsigt i deres personoplysninger (GDPR art. 15), men denne ret indskrænkes betragteligt i databeskyttelsesloven, hvis rettigheden f.eks. bør vige af hensyn til afgørende private eller offentlige interesser (databeskyttelseslovens § 22, stk. 1-2). Hensynet til den offentlige sikkerhed er et klart eksempel på en afgørende offentlig interesse. En fysisk person kan dermed ikke få indsigt i overvågningsmateriale fra en metrostation, fordi det samtidig vil afsløre kameraernes placering og dermed eventuelle blinde vinkler, som – i de forkerte hænder – kan bruges til terror (Datatilsynets j.nr. 2018-832-0009).

Det er vigtigt at være særligt opmærksom på, at dansk særlovgivning går forud for reglerne i databeskyttelsesloven (lovens § 1, stk. 3). Visse behandlinger af personoplysninger kan dermed være fastsat i anden lovgivning, f.eks. i tv-overvågningsloven, cookiebekendtgørelsen eller markedsføringsloven. Det

ligger uden for denne fremstilling at redegøre for den danske databeskyttelseslov og særlovgivning, idet fokus her er på GDPR-reglerne.

4. Aktørerne i GDPR

I GDPR optræder flere kategorier af aktører. Mest kendt er de rettigheds- og pligtssubjekter, som reglerne retter sig mod. Databeskyttelsesrettens rettighedssubjekt er 'den registrerede', hvilket er den fysiske person, som der behandles personoplysninger om. GDPR's målsætning om databeskyttelse medfører således, at det kun er registreredes oplysninger, der opnår beskyttelse ud fra en grundlæggende tanke om, at det alene er fysiske personer, som kan være private.

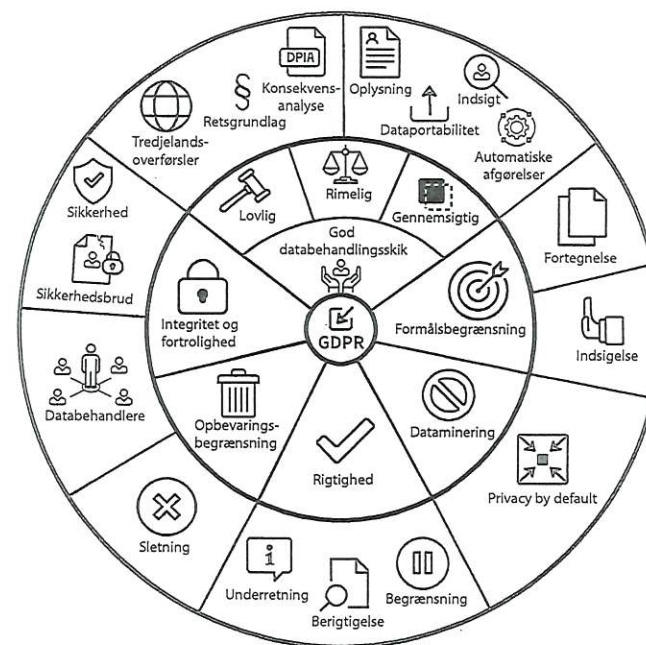
Heroverfor består pligtssubjekterne af 'den dataansvarlige' og dennes 'data-behandler'. Den dataansvarlige er, som titlen angiver, den ansvarlige for behandlingen og dermed den, som primært skal sikre iagttagelse af reglerne i GDPR (GDPR art. 24, jf. art. 5, stk. 2). Den dataansvarlige er den, som alene eller sammen med andre afgør, til hvilke formål og med hvilke hjælpemidler der må foretages behandling af den registreredes oplysninger (GDPR art. 4, nr. 7). Det er derved også muligt for to eller flere dataansvarlige at være 'fælles dataansvarlige', hvilket er tilfældet, når disse i fællesskab fastlægger formålet med og hjælpemidlerne i behandlingen (GDPR art. 26).

I praksis er den bestemmende indflydelse på et behandlingsformål afgørende for vurderingen af, om en aktør indtager rollen som dataansvarlig. Eksempelvis har it-leverandører ofte færdigudviklede systemer på det tidspunkt, hvor det er muligt for kunder (de dataansvarlige) at anvende disse, og har dermed allerede taget stilling til de hjælpemidler, som vil kunne benyttes af den enkelte kunde til at behandle personoplysninger. Hvis valg af hjælpemidler var afgørende for vurderingen, ville it-leverandørerne dermed blive (med)ansvarlige for de behandlinger af personoplysninger, som deres kunder foretager i systemet. Det vil være u hensigtsmæssigt, da it-leverandører som regel ikke har en relation til de registrerede og ikke har nogen indvirkning på formålet med behandlingen. It-leverandører indtager i stedet rollen som databehandlere, fordi de behandler personoplysninger på den dataansvarliges vegne (GDPR art. 4, nr. 8). Eksempelvis har udbyderen af et lønsystem (it-leverandør) ingen direkte relation til kundernes medarbejdere, der får udbetalt løn via systemet. Sondringen mellem dataansvarlig og databehandler kan i praksis give anledning til tvivl, men kan tit afklares ved en test af, om den

pågældende aktør kan tåle at slette personoplysninger uigenkaldeligt ved samarbejdets ophør. Hvis aktøren ikke kan tåle det, taler det klart i retning af, at den pågældende må behandle personoplysningerne til egne formål, f.eks. til dokumentation, og dermed er dataansvarlig i GDPR's forstand.

Den sidste kategori af aktører har til opgave at understøtte og/eller sikre efterlevelse af GDPR. 'Databeskyttelsesrådgiveren' er en intern aktør, som en dataansvarlig eller databehandler i visse tilfælde skal udpege, og som rådgiver om og overvåger deres efterlevelse af reglerne i GDPR (GDPR art. 37-39). Det Europæiske Databeskyttelsesråd er et europæisk organ, som har til overordnet formål at sikre ensartet anvendelse af GDPR (GDPR art. 70). Dertil kommer de dømmende aktører bestående af de enkelte EU/EØS-landes tilsynsmyndigheder og domstole samt EU-Domstolen. Det er vigtigt at være opmærksom på, at dataansvarlige, databehandlere og repræsentanter er forpligtet til at samarbejde efter anmodning fra den kompetente tilsynsmyndighed i forbindelse med udførelsen af deres opgaver (GDPR art. 27).

5. GDPR



Figur 4.1. GDPR i én figur.

I det følgende gennemgås, hvornår GDPR finder anvendelse med den følge, at den dataansvarlige skal iagttage de databeskyttelsesretlige regler. Gennemgangen tager afsæt i én overordnet GDPR-figur, som fremgår af forrige side og beskrives nærmere i det følgende.

5.1. Anvendelsesområdet for GDPR



GDPR's anvendelsesområde består af et territorielt og et materielt anvendelsesområde, som begge skal være opfyldt, før GDPR finder anvendelse. Tilsammen udgør det territoriale og materielle anvendelsesområde således døråbningen til bestemmelserne i GDPR. Det betyder, at figuren alene skal anvendes, hvis anvendelsesområdet for GDPR er opfyldt.

Det territoriale anvendelsesområde

Det territoriale anvendelsesområde udgøres af det geografiske område, hvor reglerne finder anvendelse. Behandlingen af personoplysninger skal dermed have en geografisk tilknytning til Europa. Denne geografiske tilknytning er reguleret i GDPR art. 3. Når det geografiske anvendelsesområde vurderes, er det vigtigt at være opmærksom på, at reglerne sonder mellem dataansvarlige eller databehandlere, der er etableret i eller uden for EU/EØS-landene. Om en aktør er etableret i et EU/EØS-land, er en specifik databeskyttelsesretlig vurdering i henhold til GDPR art. 3, stk. 1, og indebærer, at der sker en effektiv og faktisk udøvelse af aktivitet gennem en mere permanent struktur. Det er dermed ikke afgørende, hvor aktøren selskabsretligt er registreret. Ejendomsannoncer vedrørende ejendomme i ét EU/EØS-land, som er på det lokale sprog, og som skal betales månedligt, er tilstrækkeligt til, at en aktør er 'etableret' i det pågældende land (C-230/14 Weltimmo).

Hvis aktøren ikke er etableret i et EU/EØS-land, kan GDPR fortsat finde anvendelse, hvis betingelserne i art. 3, stk. 2, er opfyldt. Dette indebærer en eksterritorial virkning og kan siges at være udtryk for et virkningssynspunkt, så beskyttelsen i GDPR finder anvendelse på behandlinger, der har virkninger for fysiske personer, der befinder sig inden for EU/EØS. Omfattet er behandling af personoplysninger som led i udbud af varer eller tjenester til registrere-

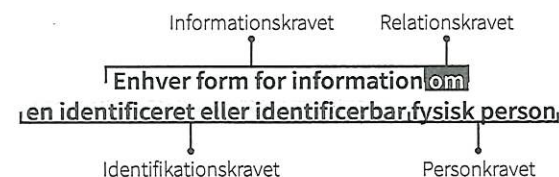
de, uanset om betaling er påkrævet, eller der sker overvågning af registreredes adfærd i EU/EØS. Dermed kan udenlandske webshops f.eks. blive omfattet af GDPR, hvis hjemmesiden præsenteres i et sprog eller valuta, der almindeligvis anvendes i et EU/EØS-land. Det betyder, at europæeres adgang til en udenlandsk hjemmeside isoleret set ikke er tilstrækkelig, fordi der kræves en tættere tilknytning mellem hjemmesiden og det respektive land, sådan at indholdet på hjemmesiden målrettes personer i EU/EØS. Der er f.eks. tale om overvågning af registreredes adfærd, hvis personer spores på internettet med henblik på at analysere eller forudsige den pågældendes præferencer, adfærd eller holdninger.

Hvis betingelserne i art. 3, stk. 2, er opfyldt, er den dataansvarlige eller databehandleren som regel forpligtet til at udpege en 'repræsentant' inden for EU (GDPR art. 27).

Det materielle anvendelsesområde

Det materielle anvendelsesområde afhænger af, om der sker en 'behandling af personoplysninger' (GDPR art. 2, stk. 1). At afgøre, om der er tale om en elektronisk 'behandling' af personoplysninger, giver sjældent anledning til problemer, fordi begrebet 'behandling' omfatter stort set alt, hvad man kan gøre eller undlade at gøre med personoplysninger (GDPR art. 4, nr. 2). Om information er en 'personoplysning', er derfor afgørende for, om registrerede på den ene side tillægges databeskyttelsesretlige rettigheder, og om dataansvarlige og databehandlere på den anden side pålægges pligter.

GDPR definerer i art. 4, nr. 1, hvad der skal forstås ved en personoplysning. Deraf kan udledes, at begrebet personoplysninger består af fire kumulative krav. En personoplysning er enhver form for information (informatonskravet), som drejer sig om en person (relationskravet), som det er muligt at identificere (identifikationskravet), forudsat personen er en fysisk person (personkravet). Figur 4.2 illustrerer princippet.



Figur 4.2. De kumulative elementer i personoplysningsbegrebet.

Informationskravet er indholdsløst, fordi det er altomfavnende. Det skyldes, at data – ifølge kravet – er information, og samtidig definerer kravet alle data som information.

Relationskravet handler om, hvor fjern relationen kan være mellem den konkrete information og den fysiske person. For eksempel er eksamensspørgsmål ikke *om* den registrerede. Det er eksamensbesvarelsen og censors noter derimod (C-582/14 – Breyer). Ifølge EU-Domstolens praksis fastlægges relationskravet ud fra en indholds-, formåls- og virkningsfortolkning, som ikke uddybes nærmere.

Identifikationskravet har til formål at vurdere, om den fysiske person kan siges at være 'identificeret' på baggrund af den konkrete informations indhold eller ved samkøring med supplerende oplysninger, som den dataansvarlige råder over. Alternativt om den pågældende er 'identificerbar'. Vurdering af, om personen er identificerbar, sker på grundlag af midler, som med rimelighed kan tænkes bragt i anvendelse af den dataansvarlige eller en anden person. Formålet med identifikationstesten er at afklare, om bearbejdning af, kendskab til eller sammenkobling med supplerende information fra en ekstern kilde nu eller i fremtiden sætter den dataansvarlige i stand til at henføre informationen til personen. Alle objektive forhold, såsom omkostninger ved og tid, der er nødvendig til identifikation, under hensyntagen til den tilgængelige teknologi på behandlingstidspunktet og den teknologiske udvikling, skal indgå i vurderingen. En person, det ikke er muligt at identificere her og nu, kan således blive identificerbar over tid på grund af den teknologiske udvikling. En person er f.eks. identificerbar, når en adresse eller et telefonnummer behandles, men hvor identifikation kræver, at den dataansvarlige indsamler supplerende information fra offentligt tilgængelige registre, såsom 118.dk eller krak.dk.

Personkravets vurdering af, om en person er 'fysisk', foretages på baggrund af objektive, konstaterbare fakta og er således simpel at foretage. Når en person er levende (har et CPR-nr.), er vedkommende en fysisk person. Når personen dør, anses vedkommende som hovedregel ikke længere for at være en 'fysisk' person. I Danmark er der imidlertid vedtaget en supplerende regel (databeskyttelseslovens § 2, stk. 5), der bestemmer, at afdøde personer beskyttes 10 år efter dødsfaldet og dermed er 'fysiske' personer i denne periode.

De databeskyttelsesretlige principper

GDPR indeholder i art. 5 en række grundlæggende principper for behandling af personoplysninger, som den dataansvarlige skal efterleve. Det skal tages bogstaveligt, at principperne er grundlæggende, fordi disse skal være opfyldt ved enhver behandling af personoplysninger. Hvis ét princip således ikke er opfyldt, er resultatet, at behandlingen er ulovlig. Det betyder, at enhver behandling omfattet af GDPR skal opfylde alle de databeskyttelsesprincipper, som vises nedenfor.



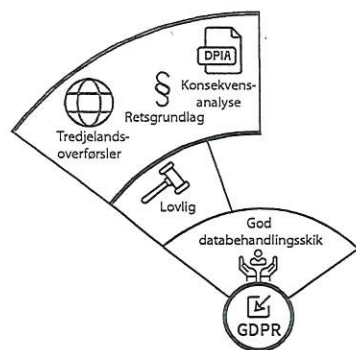
Kendetegnende for de databeskyttelsesretlige principper er desuden, at de ikke kan fraviges ved aftale. Den dataansvarlige kan dermed ikke indhente et (ellers gyldigt) samtykke fra den registrerede til at fravige principperne, bortset fra princippet om formålsbestemthed, der omtales nedenfor. Det skyldes, at den dataansvarlige f.eks. kan indhente en ansøgers samtykke til opbevaring af en jobansøgning i en længere tidsperiode end den periode, der er nødvendig til at færdigbehandle den rekrutteringsproces, som ansøgningen er modtaget i forbindelse med.

De databeskyttelsesretlige principper er nært beslægtet med 'privacy by design' (GDPR art. 25, stk. 1), idet den grundlæggende tanke er, at databeskyttelse – i form af overholdelse af principperne – skal tænkes ind i systemdesignet fra starten. GDPR tillader således ikke ibrugtagning af et system, der er blevet designet til f.eks. ikke at kunne slette personoplysninger uigenkaldeligt, alternativt anonymisere dem. Privacy by design tager navnlig sigte på udvikling af it-systemer, men finder også anvendelse på udarbejdelsen af

forretningsgange og procedurer. I praksis er GDPR art. 25, stk. 1, sjældent genstand for afgørelse og domme, fordi overtrædelserne i stedet sanktioneres ud fra det enkelte princip i art. 5.

5.2. Princippet om god databehandlingsskik

Det første princip er princippet om 'god databehandlingsskik', der rummer tre underliggende principper. Disse er principperne om lovlighed, rimelighed og gennemsigtighed, og de beskrives særskilt i det følgende.



'Princippet om lovlighed' i GDPR art. 5, stk. 1, litra a, kræver, at behandling af personoplysninger sker lovligt. Det betyder, at behandlingen skal opfylde enhver relevant regel i GDPR samt øvrig relevant lovgivning. En dataansvarlig kan dermed ikke behandle en medarbejders personoplysninger på baggrund af et lovligt samtykke, hvis behandlingen f.eks. er i strid med arbejdsretlige regler. Princippet om lovlighed er dermed et princip med betydelig bredde.

Princippet kræver bl.a., at behandlingen sker på grundlag af ét lovligt retsgrundlag i forordningen. Det betyder, at 'følsomme personoplysninger', som nævnt i GDPR art. 9, stk. 1 (f.eks. helbredsoplysninger), alene kan behandles i de undtagelsestilfælde, der opregnes i bestemmelsens stk. 2. Disse muligheder er suppleret i databeskyttelseslovens § 7. Det skal bemærkes, at der kræves et dobbelt hjemmelskrav, når der behandles følsomme personoplysninger. Det vil sige, at der også skal være et retsgrundlag til stede i art. 6, stk. 1, litra a-f. Det dobbelte hjemmelskrav har imidlertid ringe betydning i praksis, fordi retsgrundlagene i art. 6 er bredere end i art. 9.

Sondringen mellem følsomme og almindelige personoplysninger (navn,

adresse osv.) er ikke klar og må således bero på en konkret vurdering. Eksempelvis er en helbredsoplysning (følsom personoplysning) information om en persons tidligere, nuværende eller fremtidige fysiske eller mentale helbreds-tilstand (GDPR præambel nr. 35). Det er imidlertid ikke informationen, der isoleret set er afgørende for vurderingen, fordi informationen også skal vurderes ud fra, om det indirekte gennem intellektuel refleksion i form af sammenstilling eller deduktion er muligt at afsløre informationer af denne art om personen (C-184/20 OT). Oplysning om, at en person har røget gennem mange år, er således ikke isoleret set en helbredsoplysning (følsom personoplysning), men refleksion på grundlag af denne information indebærer, at det er muligt at sige noget om personens nuværende eller fremtidige fysiske helbreds-tilstand med den konsekvens, at informationen er en helbredsoplysning (følsom personoplysning) i GDPR-forstand. Derimod er en arbejdsmail med information om, at en medarbejder er syg, ikke en helbredsoplysning, fordi den information ikke sætter de modtagende medarbejdere i stand til at udlede, hvad den pågældende medarbejder fejler.

'Oplysninger om strafbare forhold' kan behandles, hvis et retsgrundlag i GDPR art. 10 eller databeskyttelseslovens § 8 er opfyldt. For eksempel vil private dataansvarlige kunne behandle oplysninger om strafbare forhold, hvis den registrerede har givet sit udtrykkelige samtykke. Hvis oplysningen hverken er følsom eller om et strafbart forhold, vil den ifølge GDPR være en 'almindelige oplysning'. Almindelige personoplysninger kan behandles, hvis der er et relevant retsgrundlag i GDPR art. 6. CPR-numre er også almindelige personoplysninger, men kan kun behandles, hvis betingelserne i databeskyttelseslovens § 11 er opfyldt. En oplysningens fortrolighed stiller ikke højere krav til retsgrundlaget. Det vil sige, at en beskyttet adresse ikke kræver et mere sikkert retsgrundlag i GDPR art. 6 end en ubeskyttet adresse.

Tredjelandsoverførsler

Når personoplysninger overføres til en modtager i et land uden for EU/EØS (kaldet et tredjeland), aktualiseres kapitel V i GDPR, der stiller supplerende krav til overførslen. Princippet om lovlighed suppleres i denne sammenhæng af det 'generelle princip for tredjelandsoverførsler' (GDPR art. 44). Dette princip gælder for overførsel af personoplysninger fra EU til et tredjeland, men også for videreoverførsler fra det respektive tredjeland til et nyt tredjeland og videreoverførsler herfra. Princippet adskiller sig i øvrigt fra de generelle

principper i GDPR art. 5, fordi både dataansvarlige og databehandlere skal iagttage princippet om tredjelandsoverførsler.

Princippet for tredjelandsoverførsler kræver, at overførslen baseres på et yderligere retsgrundlag. Det vil sige, at selve overførslen også forudsætter lovhjemmel i GDPR art. 45-49. I praksis betyder det, at en videregivelse af personoplysninger fra en dataansvarlig i EU til en anden dataansvarlig i et tredjeland kræver tre retsgrundlag, før videregivelsen kan ske lovligt. Den afgivende dataansvarlige må først sikre at kunne videregive personoplysninger lovligt i medfør af GDPR art. 6-10 (videregivelsesgrundlag). Dernæst skal tredjelandsoverførslen baseres på et retsgrundlag i GDPR art. 45-49 (overførselsgrundlag). Ligeså skal den modtagende dataansvarlige have et lovligt retsgrundlag i GDPR art. 6-10 til at kunne behandle de pågældende personoplysninger (behandlingsgrundlag). Det påhviler den afgivende dataansvarlige at sikre lovlige videregivelses-, overførsels- og behandlingsgrundlag, før personoplysningerne videregives.

Hvis en tredjelandsoverførsel ikke kan baseres på et retsgrundlag i GDPR art. 45-49, kan overførslen ikke ske lovligt. Disse artikler skal anvendes i prioriteret rækkefølge. Det vil sige, at det først skal undersøges, om der findes et overførselsgrundlag i art. 45, dernæst art. 46 osv.

GDPR art. 45 giver mulighed for at overføre personoplysninger til tredjelande på grundlag af en afgørelse truffet af EU-Kommissionen. En sådan afgørelse tager stilling til, om det pågældende tredjeland (et område eller en eller flere specifikke sektorer i dette tredjeland) eller en international organisation har et tilsvarende eller højere beskyttelsesniveau end det, som fysiske personer er garanteret i medfør af GDPR. EU-Kommissionens afgørelser tager dermed stilling til, om beskyttelsesniveauet er tilstrækkeligt, og kaldes derfor tilstrækkelighedsafgørelser. Der er tale om en helhedsvurdering, fordi EU-Kommissionen bl.a. tager tredjelandets retsstatsprincip, respekt for menneskerettighederne og de grundlæggende frihedsrettigheder i betragtning. Foreløbig har EU-Kommissionen anerkendt Andorra, Argentina, Canada (kommercielle organisationer), Færøerne, Guernsey, Israel, Isle of Man, Japan, Jersey, New Zealand, Korea, Schweiz, Storbritannien, USA (kommercielle organisationer) og Uruguay som tredjelande, der har et tilstrækkeligt niveau. Dette medfører, at disse tredjelande betragtes som 'sikre' tredjelande, så der lovligt kan overføres enhver type personoplysning om samtlige kategorier af registrerede, f.eks. også sårbare personer såsom børn, unge og handicappede.

I praksis overføres personoplysninger ofte til USA. USA er dog særegent, fordi det både er et sikkert og usikkert tredjeland. Afgørende herfor er den amerikanske modtager. Det skyldes, at EU-Kommissionens afgørelse for USA alene vedrører Data Privacy Framework-ordningen. Det vil sige, at hvis den amerikanske modtager er selvcertificeret under denne ordning (og certificeringen ikke er udløbet), vil der kunne overføres til modtageren i medfør af GDPR art. 45. Hvis modtageren ikke er selvcertificeret, er den pågældende modtager at sidestille med en modtager i et usikkert tredjeland, og derfor skal overførslen baseres på et retsgrundlag i GDPR art. 46-49.

Tredjelande, som EU-Kommissionen ikke har vedtaget en tilstrækkelighedsafgørelse for, betegnes som 'usikre' tredjelande. Tilsvarende for internationale organisationer, som derved betragtes som 'usikre' modtagere. En overførsel af personoplysninger til en modtager i et tredjeland skal, som nævnt ovenfor, baseres på et retsgrundlag i GDPR art. 46-49.

GDPR art. 46 giver mulighed for at overføre på grundlag af 'fornødne garantier', hvilket typisk sker ved brug af EU-Kommissionens standardkontraktbestemmelser (SCC'er). Bestemmelserne rummer også mulighed for, at en koncern kan indkapsle sine behandlinger af personoplysninger ved brug af 'bindende virksomhedsregler', så der ikke skal tages konkret højde for de enkelte tredjelandsoverførsler blandt de koncernforbundne selskaber (særreguleret i GDPR art. 47). Desuden kan dataansvarlige og databehandlere overføre, hvis en udenlandsk domstol eller administrativ myndighed har afsagt en dom/truffet en afgørelse, som forpligter disse til at overføre personoplysninger til et tredjeland, og den forpligtende retsakt bygger på en international aftale mellem EU eller den respektive medlemsstat og det pågældende tredjeland (GDPR art. 48). GDPR art. 49 rummer mulighed for at overføre i 'særlige tilfælde'. Anvendelsen for disse særlige tilfælde skal fortolkes snævert, hvorfor art. 49 sjældent kan benyttes i praksis.

Fælles for overførsel af personoplysninger til usikre tredjelande er, at den dataansvarlige forpligtes til at sikre det tilstrækkelige beskyttelsesniveau for overførslen. Dette indebærer, at den dataansvarlige skal udarbejde en tredjelandsvurdering (Transfer Impact Assessment – TIA) for overførslen. Den dataansvarlige skal derved sikre, at beskyttelsesniveauet for de personoplysninger, som påtænkes overført, er beskyttet på et niveau, der svarer til det, som kræves af GDPR. Overførsel af sensitive personoplysninger (følsomme personoplysninger, oplysninger om strafbare forhold, CPR-numre m.fl.)

eller almindelige personoplysninger om sårbare personer skal beskyttes i højere grad. Beskyttelsesniveauet skal bl.a. vurderes i lyset af tredjelandets nationale lovgivning, f.eks. relevant overvågningslovgivning. Dette medfører, at udarbejdelse af en tredjelandsvurdering som regel er kompleks, idet der ofte er sprog- og tilgængelighedsbarrierer, når fremmed ret fremsøges. Moderne teknologi anvendes ofte som middel for at sikre beskyttelsesniveauet for tredjelandsoverførslen. Det er bl.a. tilfældet, når de overførte personoplysninger krypteres in transit og at rest, og den modtagende part ikke har adgang til krypteringsnøglen.

Konsekvensanalyse og forudgående høring

Når en dataansvarlig vil foretage behandling af personoplysninger, der indebærer en 'høj risiko' for de berørte registrerede, er den dataansvarlige i medfør af GDPR art. 35 forpligtet til at udarbejde en konsekvensanalyse (Data Protection Impact Assessment – DPIA). Dette er f.eks. tilfældet, hvis den dataansvarlige vil bruge kunstig intelligens (AI), fordi denne brug af ny teknologi isoleret set udgør en høj risiko. Det har således ingen betydning, om der ikke påtænkes en behandling af personoplysninger i AI-modellen. Det blotte forhold, at AI-modellen betjenes af brugere, er tilstrækkeligt, fordi deres oplysninger derved behandles, f.eks. i logfiler.

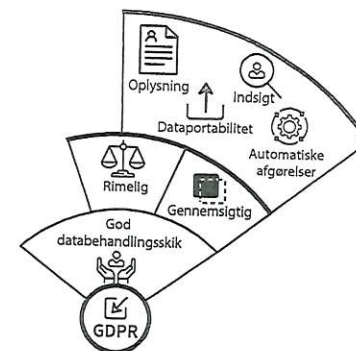
Udarbejdelse af en konsekvensanalyse er en omfattende arbejdsopgave og handler i det væsentlige om at mitigere de høje risici til et acceptabelt niveau. Konsekvensanalysen skal ifølge GDPR art. 35, stk. 7, som minimum indeholde:

1. en beskrivelse af de planlagte behandlingsaktiviteter og formålene med behandlingen,
2. en vurdering af, om behandlingsaktiviteterne er nødvendige og står i rimeligt forhold til formålene,
3. en vurdering af risiciene for de berørte registreredes (friheds)rettigheder og
4. de foranstaltninger, der påtænkes for at imødegå disse risici.

Datatilsynet har på sin hjemmeside publiceret en generel DPIA-skabelon og en skabelon specifik for AI. Heri er GDPR's fire indholdskrav udbygget, f.eks. indebærer vurderingen af, om behandlingsaktiviteterne er nødvendige og rimelige, at alle de databeskyttelsesretlige principper vurderes.

Hvis den dataansvarlige har udpeget en databeskyttelsesrådgiver, skal den

dataansvarlige rådføre sig med denne, når der foretages en konsekvensanalyse, og før den godkendes (GDPR art. 35, stk. 2). I tilfældet af at de høje risici ikke kan mitigeres til et acceptabelt niveau, er den dataansvarlige forpligtet til at foretage en forudgående høring ved Datatilsynet (GDPR art. 36).



GDPR art. 5, stk. 1, litra a, indeholder også et princip om 'rimelighed' og 'gennemsigtighed'.

Princippet om 'rimelighed' rummer en proportionalitetsbetragtning forstået på den måde, at behandlingens rimelighed vurderes ud fra en vægtning af formålet med behandlingen på den ene side og hensynene til den registrerede på den anden side. Hvis en applikation f.eks. tillader brugeren at se sportsresultater mv., men samtidig bruges til at opdage, om beværgninger viser storkampe uden tilladelse på grundlag af oplysning om GPS-lokation og lydoptagelser fra mikrofonen, er dette ikke rimeligt.

Ret til dataportabilitet og til ikke at være genstand for en automatisk afgørelse

Princippet om rimelighed ses især udmøntet i to af de registreredes databeskyttelsesrettigheder: retten til dataportabilitet og retten til ikke at være genstand for en automatisk afgørelse.

'Ret til dataportabilitet' (GDPR art. 20) giver den registrerede adgang til at kræve sine personoplysninger udleveret i et format, som gør dem mulige at overtage af en anden dataansvarlig. Denne rettighed er udtryk for en rimelighedsbetragtning, fordi den registrerede dermed undgår at blive bundet til en dataansvarlig, eftersom rettigheden giver lettere adgang til at skifte til en konkurrerende tjeneste. For eksempel kan forbrugere – med tiden – danne adskillige personlige playlister i en musikstreamingtjeneste, der knytter forbrugeren

til udbyderen af tjenesten. Retten til dataportabilitet sikrer, at forbrugeren kan få de dannede playlister – og anden personlig information – udleveret i et struktureret, almindeligt anvendt og maskinlæsbart format, så det er muligt at eksportere playlisterne til en ny musikstreamingtjeneste. Retten til dataportabilitet kan dermed i realiteten siges at have mere karakter af en forbrugerrettighed end en databeskyttelsesrettighed. Rettigheden udfordres dog af, at GDPR ikke fastslår, hvornår et maskinlæsbart format er 'almindeligt anvendt', hvilket således må bero på en konkret vurdering, eftersom den stigende digitalisering gradvist flytter grænsen herfor.

GPPR art. 22 fastsætter, at registrerede har ret til ikke at være genstand for automatiserede individuelle afgørelser. Denne rettighed har fået større praktisk betydning i forbindelse med den stigende brug af kunstig intelligens og er også udtryk for en rimelighedsbetragtning. Den registrerede har nemlig krav på menneskelig indblanding, hvis den automatiske afgørelse har retsvirkning eller på tilsvarende vis betydeligt påvirker den pågældende. Dermed har f.eks. en bankkunde typisk krav på at få foretaget en manuel kreditvurdering, medmindre den automatiske kreditvurdering er nødvendig for indgåelse eller opfyldelse af en kontrakt mellem den registrerede og den dataansvarlige eller kan foretages på grundlag af lovgivningen, eller hvis den registrerede har givet sit udtrykkelige samtykke (GDPR art. 22, stk. 2).

Princippet om 'gennemsigtighed' handler om, at den registrerede kender til behandlingens eksistens og omfang, så denne har en reel mulighed for at gennemskue behandlingen. Den dataansvarlige skal dermed gøre den registrerede bekendt med behandlingsaktiviteten efter reglerne om oplysningspligt (proaktiv pligt) og retten til indsigt (reaktiv pligt), som dermed er nært beslægtet med princippet.

Oplysningspligten

Registrerede har krav på at modtage oplysninger om behandlingen af deres personoplysninger. Det er den dataansvarlige, som skal opfylde denne oplysningspligt. GDPR rummer dog to forskellige oplysningspligter. Hvis den dataansvarlige modtager personoplysningerne direkte fra den registrerede, skal oplysningspligten iagttage kravene i GDPR art. 13. Hvis personoplysningerne derimod indsamles fra en anden end den registrerede, skal oplysningspligten overholdes efter GDPR art. 14.

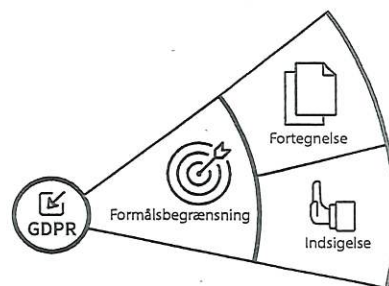
I praksis forekommer det ofte, at personoplysninger indsamles fra både den registrerede og andre kilder, f.eks. i forbindelse med en rekruttering, hvor ansøgning og CV modtages fra jobansøgeren, mens referencer indsamles fra andre. I sådanne tilfælde iagttages oplysningspligten typisk i form af en samlet oplysningsskrivelse (kaldet en privatlivspolitik), der iagttager kravene i begge bestemmelser. Forskellen på de to oplysningspligter er hovedsagelig fristen for opfyldelse og minimumskravene til indholdet. Når personoplysninger indsamles direkte fra den registrerede, skal denne modtage privatlivspolitikken på det tidspunkt, hvor personoplysninger behandles (GDPR art. 13, stk. 1), dvs. på behandlingspunktet, som ofte er sammenfaldende med tidspunktet for indsamling. De tekniske muligheder for nem og hurtig behandling af personoplysninger udfordrer dette krav. For eksempel er det jo umuligt for dataansvarlige at forudse, hvilken person der lægger en telefonsvarerbesked og formålet hermed, sådan at der ikke samtidig kan gives en fyldestgørende privatlivspolitik. GDPR art. 13 kræver nemlig, at der gives oplysninger om formålene med behandlingen af de pågældende personoplysninger, retsgrundlaget for behandlingen, modtagerne af oplysningerne, opbevaringsperioden mv. For så vidt angår den anden oplysningspligt i GDPR art. 14, skal den dataansvarlige give den registrerede privatlivspolitikken første gang, den dataansvarlige kommunikerer med personen, eller når personoplysningerne videregives første gang, men uanset hvad inden for en måned. GDPR art. 14 stiller desuden to yderligere indholdskrav til privatlivspolitikken: de berørte kategorier af personoplysninger (almindelige og følsomme personoplysninger og oplysninger om strafbare forhold), og hvilken kilde personoplysninger stammer fra (GDPR art. 1, stk. 1, litra d, og art. 14, stk. 2, litra f).

Ret til indsigt

Registrerede har desuden en 'ret til indsigt' i de personoplysninger, som den dataansvarlige behandler om den pågældende (GDPR art. 15). Rettigheden giver den registrerede mulighed for at modtage en kopi af de personoplysninger, der behandles, og en række supplerende oplysninger, som i det væsentlige svarer til de indholdsmæssige krav til privatlivspolitikken i GDPR art. 13. Udøvelsen af denne rettighed er som regel forbundet med et stort ressourceforbrug for de dataansvarlige, hvilket har ført til, at rettigheden også er set anvendt som pressionsmiddel. Eksempelvis giver retten også ret til ind-

sigt i logfiler, hvis den registreredes personoplysninger indgår heri (C-579/21 J.M.). Hvis den dataansvarlige skal betale databehandlere for at trække de pågældende logoplysninger, kan det således være mere nærliggende for den dataansvarlige at godtage en (uretmæssig) reklamation fremfor at meddele indsigt. Dette skal især ses i lyset af de formelle krav i GDPR art. 12, som f.eks. kræver, at logfilen skal præsenteres i en "kortfattet, gennemsigtig, letforståelig og lettilgængelig form og i et klart og enkelt sprog". Den dataansvarlige har dog mulighed for at afvise en indsigtsanmodning (eller udøvelse af en anden rettighed), hvis anmodningen er åbenbart grundløs eller overdreven (GDPR art. 12, stk. 5). Det er imidlertid den dataansvarliges bevisbyrde, at rettighedsanmodningen retmæssigt kan afvises, og i praksis fortolkes bevisbyrden strengt med den konsekvens, at den dataansvarlige løber en væsentlig standpunktsrisiko ved afvisning af en rettighedsanmodning.

5.3. Princippet om formålsbegrænsning



Princippet om 'formålsbegrænsning' i art. 5, stk. 1, litra b, begrænser den dataansvarlige til kun at måtte indsamle personoplysninger til udtrykkeligt angivne og legitime formål og ikke viderebehandle disse oplysninger på en måde, som er uforenelig med disse formål.

Den dataansvarlige skal dermed gøre sig klart, hvad formålet med behandlingen er, og om behandlingen er saglig. Dette formål fastlægger således de retlige rammer for, hvilke formål personoplysningerne må behandles til. Den dataansvarlige kan herefter viderebehandle personoplysningerne til formål, som er forenelige med det oprindelige formål, men ikke til uforenelige formål. Denne uforenelighedstest skal udføres i henhold til GDPR art. 6, stk. 4, hvil-

ket indebærer, at der bl.a. skal tages højde for forbindelsen til det oprindelige formål, kategorien af de personoplysninger, som behandles, og de mulige konsekvenser for den registrerede. Hvis viderebehandlingen sker til et uforeneligt formål, skal den dataansvarlige sikre et retsgrundlag for viderebehandlingen, ligesom oplysningspligten skal iagttages på ny.

Fortegnelse

Den dataansvarliges fastlæggelse af formålet med behandlingen er forbundet med pligten til at føre en fortegnelse (GDPR art. 30), idet en fortegnelse er et internt overblik over formålene med behandling af personoplysninger, og har derfor til formål at være et centralt middel for compliancearbejdet. Samtidig er dataansvarlige og databehandlere forpligtede til at stille fortegnelsen til rådighed for Datatilsynet (GDPR art. 30, stk. 4).

Kravet om at føre en fortegnelse gælder både for den dataansvarlige og databehandleren, men der stilles forskellige indholdsmæssige krav. Begge fortegnelser skal dog føres skriftligt, herunder elektronisk (GDPR art. 30, stk. 3). De dataansvarliges fortegnelse skal ifølge GDPR art. 30, stk. 1, som minimum rumme information om:

- navn og kontaktoplysninger på den dataansvarlige (og hvis relevant den fælles dataansvarlige, dennes repræsentant og databeskyttelsesrådgiveren),
- formålene med behandlingen,
- en beskrivelse af kategorierne af registrerede og kategorier af personoplysninger,
- kategorier af modtagere,
- oplysning om eventuelle tredjelandsoverførsler,
- de forventede tidsfrister for sletning af de forskellige kategorier af oplysninger og
- en generel beskrivelse af de tekniske og organisatoriske sikkerhedsforanstaltninger.

Der stilles færre indholdskrav til databehandlerens fortegnelse (GDPR art. 30, stk. 2). I praksis kræves, at fortegnelsen udarbejdes på en måde, som sikrer, at den bliver konkret og praktisk anvendelig for både den dataansvarlige/databehandleren og Datatilsynet. Det betyder, at det f.eks. ikke er tilstrækkeligt at

angive kategorien 'følsomme personoplysninger' i fortegnelsen. Det skal være muligt at udlede, hvilken følsom personoplysning der menes, f.eks. helbredsoplysninger eller fagforeningsmæssigt tilhørsforhold (Datatilsynet j.nr. 2018-423-0018). Dermed lægges vægt på, at kravet om at udarbejde fortegnelser ikke blot bliver et formelt krav, og at fortegnelserne skal have en reel indholdsmæssig værdi, så de udarbejdes på en måde, som skaber et reelt overblik over de pågældende behandlinger og danner et grundlæggende fundament for den dataansvarliges/databehandlers generelle overholdelse af databeskyttelsesreglerne (Datatilsynets j.nr. 2018-423-0020).

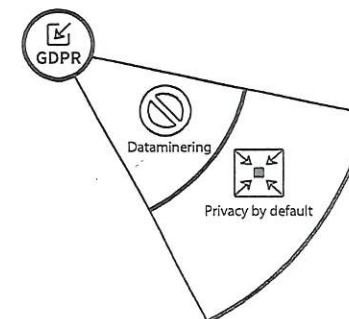
Hvis dataansvarlige eller databehandlere beskæftiger mindre end 250 personer, er der mulighed for at blive undtaget fra kravet om at føre en fortegnelse (GDPR art. 30, stk. 5). Dette kræver imidlertid, at behandlingsaktiviteterne ikke sandsynligvis rummer en risiko for de registreredes (friheds)rettigheder, og at behandlingen sker lejlighedsvis og ikke omfatter særlige kategorier af personoplysninger (følsomme personoplysninger og oplysninger om strafbare forhold).

Ret til indsigelse

I visse tilfælde har registrerede 'ret til indsigelse' mod den behandling, som den dataansvarlige har fastlagt formålet med (GDPR art. 21). Det er åbenbart, at den registrerede altid kan gøre indsigelse mod en ulovlig behandling, men indsigelsesretten i GDPR art. 21 angår alene behandling af personoplysninger, der sker som led i offentlig myndighedsudøvelse (GDPR art. 6, stk. 1, litra e) eller på grundlag af interesseafvejningsreglen (GDPR art. 6, stk. 1, litra f).

Hvis en dataansvarlig modtager en indsigelse mod en behandlingsaktivitet, skal den dataansvarlige vurdere, om behandlingen er nødvendig, for at retskrav kan fastlægges, gøres gældende eller forsvares, eller der er vægtige legitime grunde til at opretholde behandlingen; legitime grunde, der går forud for den registreredes (friheds)rettigheder. I tilfælde af, at hensynet til den registrerede overstiger hensynet til den dataansvarlige, må den dataansvarlige ikke længere behandle personoplysningerne. Dette er f.eks. tilfældet for direkte markedsføring (GDPR art. 21, stk. 2-3).

5.4. Princippet om dataminimering

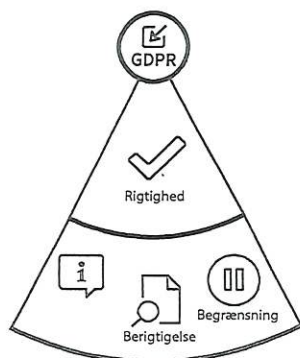


GDPR art. 5, stk. 1, litra c, indeholder princippet om 'dataminimering'. Dette princip kræver, at personoplysninger skal være tilstrækkelige, relevante og begrænset til, hvad der er nødvendigt i forhold til de formål, hvortil de behandles. Dermed kan dataansvarlige behandle oplysninger, som er *need-to*, men ikke *nice-to*. For eksempel er oplysning om tiltaleform (Mr. og Mrs.) ikke nødvendig at indsamle, når formålet er kontrol af togbilletter (C-394/23 Mousse). Den dataansvarlige skal udføre nødvendighedsvurderingen ud fra formålet, som er fastlagt i henhold til princippet om formålsbestemthed.

Privacy by default

Princippet om dataminimering er nært beslægtet med 'privacy by default' (GDPR art. 25, stk. 2), fordi formålet med dette krav er at sikre, at der kun sker behandling af personoplysninger, der er nødvendige for det specifikke formål med behandlingen. Den dataansvarlige skal dermed sikre, at standardindstillinger er sat så tilpas snævert, at det f.eks. ikke er muligt at få adgang til personoplysninger, som de respektive brugere ikke har et behov for at tilgå. For eksempel skal udbyderen af et socialt medie sikre, at standardindstillingerne alene gør det muligt for den registreredes venner at se den pågældendes aktivitet på det sociale medie. Den registrerede kan herefter vælge at åbne op, så offentligheden kan tilgå dennes profil (offentlig profil).

5.5. Princippet om rigtighed



Ifølge princippet om 'rigtighed' skal den dataansvarlige sikre, at personoplysninger er korrekte og om nødvendigt ajourførte, og tage ethvert rimeligt skridt for at sikre, at personoplysninger, som er urigtige, straks slettes eller berigtiges. Princippet har til formål at dæmme op for, at urigtige oplysninger f.eks. fører til forkerte forvaltningsafgørelser eller forkert kreditvurdering.

Urigtige oplysninger dækker objektivt forkerte personoplysninger, men også andre oplysninger, der er vildledende eller ufuldstændige (f.eks. menings-tilkendegivelser eller citater). Hvis der behandles urigtige oplysninger, har den dataansvarlige en pligt til at slette eller berigtige disse, medmindre den dataansvarlige er en offentlig myndighed. En offentlig myndighed skal i stedet notere, at den pågældende oplysning er urigtig, men fortsat opbevare den og notere den korrekte.

Ret til berigtigelse og begrænsning

Registrerede har 'ret til berigtigelse', hvilket indebærer en ret til at få berigtiget urigtige personoplysninger om sig selv uden unødigt forsinkelse eller få fuldstændiggjort ufuldstændige personoplysninger (GDPR art. 16). Der er således en klar forbindelse mellem princippet om rigtighed og retten til berigtigelse.

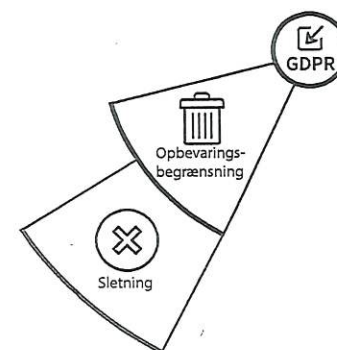
Det er vigtigt at være opmærksom på, at den registreredes opfattelse ikke er afgørende for retten til berigtigelse. Det vil sige, at blot fordi en person mener, at en bestemt oplysning er urigtig, betyder det ikke nødvendigvis, at den dataansvarlige er forpligtet til at berigtige oplysningen. I stedet afhænger rettigheden af den dataansvarliges konkrete vurdering. Det betyder, at hvis der er uenighed om, hvorvidt personoplysningen er urigtig, er den dataan-

svarlige ikke forpligtet til at berigtige oplysningen, men der skal tilføjes, at den registrerede ikke mener, at oplysningen er korrekt. Der er i øvrigt heller ingen forpligtelse til at berigtige subjektive eller faglige vurderinger (men den registreredes synspunkt skal tilføjes).

Den registrerede har også 'ret til begrænsning' af behandlingen, hvilket bl.a. er tilfældet, hvis den registrerede bestrider rigtigheden af en personoplysning (GDPR art. 18). Rettigheden medfører, at den dataansvarlige alene må opbevare personoplysningerne, medmindre behandlingen sker med den registreredes samtykke, med henblik på at et retskrav kan fastlægges, gøres gældende eller forsvares, beskytte en juridisk eller fysisk person eller forsvare vigtige samfundsinteresser (GDPR art. 18, stk. 2). Hvis den dataansvarlige ophæver begrænsningen af behandlingen til ét af disse formål, skal den registrerede underrettes forinden (GDPR art. 18, stk. 3).

I de tilfælde, hvor en dataansvarlig har overladt eller videregivet de personoplysninger, som en registreret har anmodet om at få berigtiget eller behandlingen af dem begrænset, til en modtager, skal den dataansvarlige underrette alle modtagere herom (GDPR art. 19). Medmindre denne underretningsforpligtelse viser sig umulig eller er uforholdsmæssig vanskelig.

5.6. Princippet om opbevaringsbegrænsning



Princippet om 'opbevaringsbegrænsning' i art. 5, stk. 1, litra e, kræver, at personoplysninger ikke opbevares i et længere tidsrum end det, der er nødvendigt til de formål, hvortil de behandles. Den dataansvarlige skal sikre, at der ikke sker en dataophobning (såkaldte datakirkegårde) med personoplysninger, som ikke længere er relevante at behandle. Princippet pålægger dermed de dataan-

svarlige en aktiv forpligtelse til at påse, at personoplysninger slettes rettidigt, hvilket er et supplement til den registreredes ret til sletning, der er afhængig af, at den registrerede udøver rettigheden (reaktiv rettighed). Det vil bero på en konkret vurdering, hvor lang tid personoplysningerne kan opbevares, men ofte vil forældelsesfrister eller retlige dokumentationsperioder danne grundlaget for opbevaringsperioden. For eksempel vil oplysninger fra et kundeforhold typisk kunne opbevares i tre år på grund af dansk rets almindelige forældelsesregel (forældelseslovens § 3, stk. 1); fem år for ansættelsesforhold (forældelseslovens § 4).

Retten til sletning

Registreredes 'ret til sletning' er nært knyttet til princippet om opbevaringsbegrænsning, fordi rettigheden medfører, at personoplysninger bl.a. skal slettes uden unødigt forsinkelse, hvis de ikke længere er nødvendige til at opfylde de formål, hvortil de blev indsamlet eller på anden vis behandlet (GDPR art. 17). Rettigheden finder også anvendelse, hvis den registrerede f.eks. trækker sit samtykke tilbage, hvis personoplysningerne er blevet behandlet ulovligt, eller hvis oplysninger skal slettes for at overholde en retlig forpligtelse, som den dataansvarlige er pålagt. Det siges, at der ikke er andet tilbage af retten til sletning end rettighedens overskrift, fordi rettigheden omfatter tilfælde, hvor sletning allerede burde være foretaget. Hvis den dataansvarlige vurderer, at den registrerede har ret til sletning, gælder underretningspligten i GDPR art. 19, der er beskrevet ovenfor.

Databehandlere

Ifølge GDPR art. 28, stk. 1, må dataansvarlige alene gøre brug af databehandlere, der stiller fornødne garantier for, at de opfylder bestemmelserne i GDPR. Disse fornødne garantier skal være reguleret i en databehandleraftale, som er en kontrakt eller et andet retligt dokument, som er bindende for databehandleren (GDPR art. 28, stk. 3).

Brug af en databehandler bør forstås som et fuldmagtsforhold, idet databehandleren agerer på tilladelse af den dataansvarlige. Det vil sige, at databehandleren behandler de respektive personoplysninger på vegne af den dataansvarlige. Databehandleraftalen udgør derfor databehandlerens instruks

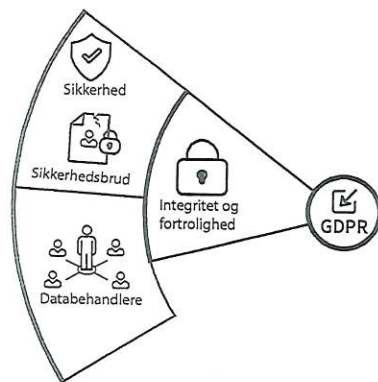
(fuldmagt), fordi denne sætter rammerne for, hvordan databehandleren må behandle personoplysningerne. Databehandlerkonstruktionen indebærer, at den dataansvarlige ikke skal have et videregivelsesgrundlag for at give personoplysningerne til databehandleren. Personoplysninger overlades i stedet. Databehandleren skal heller ikke opfylde oplysningspligten over for de berørte registrerede, da behandlingen jo netop foretages på vegne af den dataansvarlige. Hvis databehandleren sprænger rammerne af instruksen (handler uden for fuldmagten), medfører det, at databehandleren bliver selvstændig dataansvarlig (GDPR art. 28, stk. 10, og art. 29).

GDPR stiller en række indholdskrav, der som minimum skal være fastsat i aftaledokumentet (GDPR art. 28, stk. 3). Hvis disse ikke er iagttaget, er aftalen ugyldig. Databehandleraftalen skal bl.a. fastsætte genstanden for og varigheden af behandlingen, behandlingens karakter og formål, typen af personoplysninger og kategorierne af registrerede samt den dataansvarliges rettigheder og forpligtelser.

Databehandleren kan ved forudgående generel eller specifik skriftlig godkendelse gøre brug af en anden databehandler (underdatabehandler). I sådanne tilfælde skal indgås en underdatabehandleraftale mellem databehandleren og underdatabehandleren, hvori underdatabehandleren pålægges de samme databeskyttelsesforpligtelser som dem, der er fastsat i hoveddatabehandleraftalen mellem den dataansvarlige og databehandleren (GDPR art. 28, stk. 4). Dette omtales som spejlingsforpligtelsen og har til formål at sikre, at databeskyttelsen ikke udvandes ned i databehandlerkæden.

Brug af (under)databehandlere medfører, at den dataansvarlige skal føre tilsyn med disse. Tilsynsformen og -hyppigheden er risikobaseret og afhænger derfor af karakteren af behandlingen. Det vil sige, at hvis der behandles følsomme personoplysninger om sårbare registrerede i stort omfang, skal der føres et mere intensiveret tilsyn, f.eks. i form af en årlig ISAE 3000- eller ISAE 3402-erklæring udarbejdet af en uafhængig part. Modsat er et årligt skriftligt spørgeskema fremsendt til databehandleren af den dataansvarlige tilstrækkeligt, hvis der blot behandles almindelige personoplysninger i begrænset omfang.

5.7. Princippet om integritet og fortrolighed



GDPR art. 5, stk. 1, litra f, indeholder princippet om 'integritet og fortrolighed', som pålægger den dataansvarlige at sikre, at personoplysninger behandles på en måde, der fører til tilstrækkelig sikkerhed for de pågældende personoplysninger, herunder beskyttelse mod uautoriseret eller ulovlig behandling og mod hændeligt tab, tilintetgørelse eller beskadigelse under anvendelse af passende tekniske og organisatoriske sikkerhedsforanstaltninger. En teknisk foranstaltning er f.eks. en firewall, antivirus eller en multifaktorgodkendelse, hvor en organisatorisk foranstaltning f.eks. kan være brand- eller tyverialarm, lås på fysiske døre, træning eller retningslinjer for medarbejdere. Princippet knæsetter dermed en forpligtelse for den dataansvarlige til at etablere en passende behandlingssikkerhed ved gennemførelse af effektive foranstaltninger.

Passende behandlingssikkerhed

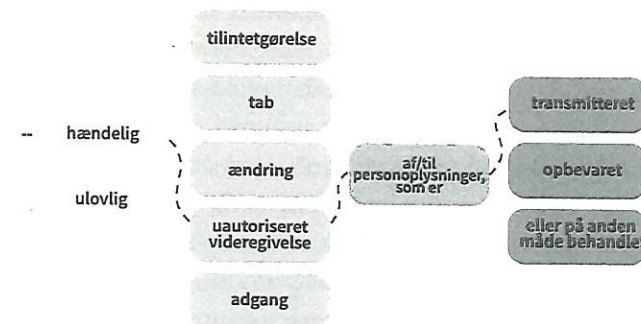
Princippet om integritet og fortrolighed fremgår mere detaljeret af GDPR art. 32, der stiller et generelt krav om passende behandlingssikkerhed. Denne bestemmelse afgør dermed primært, hvilke sikkerhedskrav der kan stilles til den dataansvarlige eller databehandlerens behandling af personoplysninger. Princippet om integritet og fortrolighed har dermed begrænset betydning i praksis, men har en signalværdi, eftersom behandlingssikkerhed er gjort til et grundlæggende behandlingsprincip.

GDPR art. 32 er risikobaseret, hvilket vil sige, at de tekniske og organisatoriske foranstaltninger fastlægges på baggrund af behandlingens karakter. Dette sker ved udførelse af en risikovurdering. GDPR stiller ikke krav om

brug af en bestemt risikovurderingsmodel, og der er således metodefrihed. Datatilsynet har dog anbefalet brug af følgende model: konsekvens $\times$ sandsynlighed = risiko. I praksis anvendes ofte risikomatrixer i spændet 3×3 , 4×4 eller 5×5 . Ved brug af en risikomatrix på 3×3 har konsekvensvurderingen dermed tre udfaldsrum (lav, mellem og høj konsekvens). Tilsvarende for sandsynlighedsvurderingen. Eksempelvis kan behandling af CPR-numre f.eks. lede til identitetstyveri (3 – høj konsekvens), men hvis CPR-numrene alene behandles i krypteret form, vil der være en lav sandsynlighed (1) for, at oplysningen kompromitteres. Dermed vil risikoen for denne behandling være lav, fordi den samlede score vil være på 3 (3×1). Hvis CPR-numrene i stedet behandles i klar tekst, vil der være en høj sandsynlighed (3) for kompromittering. Risikobilledet for behandlingsaktiviteten vil dermed være uacceptabelt, eftersom der vil være en høj risiko ($3 \times 3 = 9$). Hvis dette ikke kan mitigeres, vil den dataansvarlige være forpligtet til at udarbejde en konsekvensanalyse i henhold til GDPR art. 35, jf. ovenfor.

Håndtering af sikkerhedsbrud

Der foreligger et sikkerhedsbrud i GDPR-forstand, hvis der sker hændelig eller ulovlig tilintetgørelse, tab, ændring, uautoriseret videregivelse af eller adgang til personoplysninger, der er transmitteret, opbevaret eller på anden måde behandlet (GDPR art. 4, nr. 12). Dette er f.eks. tilfældet ved en mail, der sendes til den forkerte modtager, hackerangreb eller tyveri af en computer eller harddisk, som der er lagret personoplysninger på. Definitionen af et sikkerhedsbrud kan bedst illustreres ved nedenstående figur. Hvis det er muligt at trække en streg gennem de fire kolonner, vil der være tale om et sikkerhedsbrud (figur 4.3).



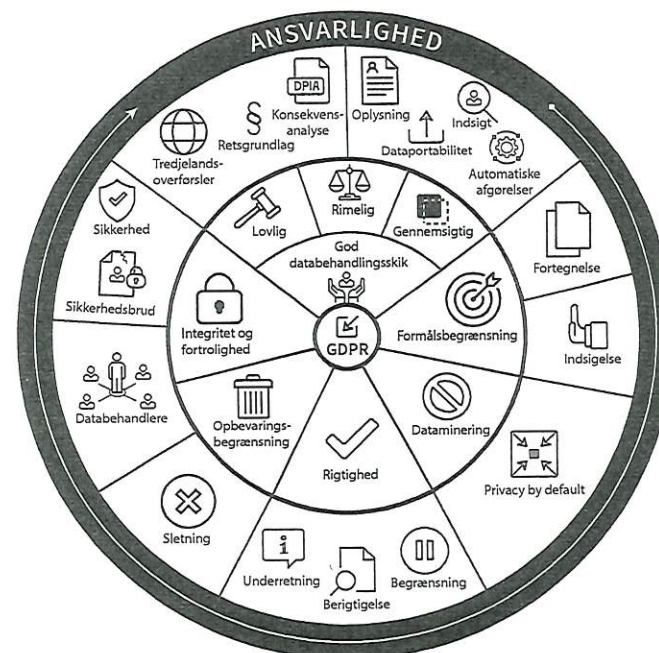
Figur 4.3. Illustration af definitionen på et sikkerhedsbrud.

Den dataansvarlige er forpligtet til at anmelde et sikkerhedsbrud til Datatilsynet, medmindre det er usandsynligt, at bruddet indebærer en risiko for de berørte registrerede (GDPR art. 33, stk. 1). En mail til en forkert læge skal således ikke anmeldes, fordi lægen er underlagt en lovbestemt tavshedspligt og er vant til at omgå personoplysninger med den konsekvens, at bruddet ikke indebærer en risiko for de personer, hvis oplysninger er indeholdt i mailen. Hvis bruddet derimod vurderes til at indebære en risiko for de registrerede, skal bruddet anmeldes til Datatilsynet uden unødigt forsinkelse og om muligt senest 72 timer efter, at den dataansvarlige er blevet bekendt med bruddet (GDPR art. 33, stk. 1). Anmeldelsesfristen tager ikke højde for ferier, week-ender eller helligdage. Hvis sikkerhedsbruddet opdages af en databehandler, skal denne underrette den dataansvarlige herom uden unødigt forsinkelse efter at være blevet opmærksom på bruddet (GDPR art. 33, stk. 2).

GDPR stiller en række krav til de oplysninger, der skal være indeholdt i anmeldelsen til Datatilsynet. Disse fremgår af GDPR art. 33, stk. 3, og afspejles i anmeldelsesformularen på virk.dk, som skal anvendes i forbindelse med anmeldelsen. Hvis den dataansvarlige ikke kan afgive alle de påkrævede oplysninger inden for anmeldelsesfristen, skal oplysningerne meddeles trinvist uden unødigt forsinkelse (GDPR art. 33, stk. 4). Uanset om sikkerhedsbruddet skal anmeldes eller ej, er den dataansvarlige forpligtet til at dokumentere alle brud på persondatasikkerheden (GDPR art. 33, stk. 5).

De sikkerhedsbrud, der indebærer en høj risiko for de registrerede, medfører, at den dataansvarlige skal foretage en underretning af den enkelte berørte registrerede (GDPR art. 34, stk. 1), medmindre der er blevet gennemført passende sikkerhedsforanstaltninger, eller hvis underretningen vil kræve en uforholdsmæssig indsats (GDPR art. 34, stk. 3). Ifølge Datatilsynet er det forbundet med høj risiko, hvis et CPR-nummer er blevet lækket.

5.8. Princippet om ansvarlighed



GDPR art. 5, stk. 2, indeholder 'princippet om ansvarlighed', der forpligter dataansvarlige til at påvise overholdelse af de grundlæggende principper. Dette påvisningskrav fordrer derved udarbejdelse af interne procedurer, retningslinjer, vurderinger og analyser, som sætter dataansvarlige i stand til at dokumentere efterlevelse af principperne om god databehandlingsskik, formålsbegrænsning, dataminimering, rigtighed, opbevaringsbegrænsning og integritet og fortrolighed. Det er således utilstrækkeligt, hvis den dataansvarlige henviser til forudgående overvejelser, f.eks. tanker om, at denne ikke var forpligtet til at udpege en databeskyttelsesrådgiver efter GDPR art. 37, eftersom princippet kræver et mere håndfast bevis for vurderingen, såsom en intern skriftlig vurdering, som adresserer de relevante bedømmelselementer relateret til kravet om udpegelse af en databeskyttelsesrådgiver.

Princippet om ansvarlighed har været og bliver fortsat udskældt for at afføde en ressourcekrævende complianceopgave, fordi efterlevelse kræver et omfangsrigt dokumentationsspor parallelt med den praktiske efterlevelse, der

løbende skal vedligeholdes – et dokumentationsspor, det tager lang tid at udarbejde. Særligt brug af ny teknologi, såsom kunstig intelligens, udfordrer dette, fordi teknologien ofte efterspørges her og nu i dataansvarliges organisationer og i visse tilfælde blot bliver en del af it-miljøet 'over night' (f.eks. Microsofts lancering af Copilot i Edge). Dertil er det de færreste dataansvarlige, der har fundet en måde at efterleve princippet om ansvarlighed på, så compliance-dokumentationen skaber en reel værdi i organisationen og er mulig at vedligeholde over tid, hvilket har ledt til, at flere (desværre) betegner de enkelte compliance-dokumenter som 'papirtigre'.

Det er dog vigtigt at holde sig for øje, at princippet om ansvarlighed udgør 'the back bone' i den databeskyttelsesretlige regulering forstået på den måde, at compliance-dokumentationen tjener et bredere formål end at påvise den dataansvarliges efterlevelse af de grundlæggende principper. Således rettes procedurer og retningslinjer f.eks. mod den dataansvarliges autoriserede medarbejdere, sådan at der – ved brug af disse – opsættes en klar ramme for deres respektive behandling af personoplysninger. Procedurer og retningslinjer tjener således et dokumentationsformål, fordi disse påviser den dataansvarliges efterlevelse, men udgør samtidig den medarbejdervendte instruks i relation til behandling af personoplysninger.

6. Afslutning

GDPR er, ifølge EU-Kommissionen, en af "hjørnestenene i EU's tilgang til den digitale omstilling" (EU-Kommissionens første rapport om databeskyttelse som en hjørnestein i borgernes indflydelse). Denne europæiske politikudformning sætter fysiske personers ret til databeskyttelse i centrum for den digitale omstilling, hvilket betyder, at GDPR er "rettesnor for brugen af teknologi i den grønne og den digitale omstilling" (samme rapport). Dette har bl.a. til formål at opnå sikre onlinemiljøer og sikre udvikling af AI-modeller. Fordi brug af teknologi således skal ske med respekt for databeskyttelsesreglerne i GDPR, udgør regelsættet en regulatorisk bremse for den teknologiske udvikling. Dette kan synes hensigtsmæssigt ud fra en rettighedsbetragtning, men fremtræder i et større perspektiv bl.a. som en forringelse af europæiske virksomheders konkurrenceevne over for andre virksomheder og en hindring for offentlige myndigheders brug af ny teknologi, f.eks. fordi de databeskyttelsesretlige krav efterlader en retlig usikkerhed i forhold til, om teknologien

kan bruges lovligt, fordi efterlevelse af GDPR kræver et omfattende compliance-regime, og fordi deling af data for at fremme vækst eller digitaliseringen ofte blokeres af GDPR.

Heroverfor har EU-Kommissionen udråbt de kommende år til EU's digitale årti, hvor f.eks. mindst 75 % af de europæiske virksomheder skal anvende cloudtjenester, big data og kunstig intelligens inden 2030. Virksomheder udfordres imidlertid af det compliancearbejde, der følger med brugen af disse teknologiske muligheder, fordi det kræver, at hver virksomhed sikrer, at dens complianceramme løbende tilpasses de 'virkelige' forhold. Eksempelvis ændrer Microsoft månedligt sine Privacy and Security Terms, hvilket betyder, at der hver måned skal ske kontrol af disse. Dertil skal det kontrolleres, om teknologiens funktioner ændres/udvides, om databehandlerkæden er ændret, om virksomhedens settings for den pågældende teknologi er ændret, om der er sket en udvikling i rets- eller administrativ praksis osv. Dette medfører, at store virksomheder har mulighed for at benytte ny teknologi og dermed opnå optimering af arbejdsgange, tilbyde teknologiprægede tjenester mv., hvorimod SMV'er ikke kan benytte samme muligheder på grund af omkostningerne til at sikre løbende compliance. Den politiske ambition om, at mindst 75 % af de europæiske virksomheder skal anvende cloudtjenester, big data og kunstig intelligens inden 2030, udfordres dermed af den retlige realitet, hvor GDPR stiller store (compliance)krav til virksomheden uanset dens størrelse.

GDPR fremmer således et højt niveau af privatlivsbeskyttelse, hvilket sker på bekostning af andre samfundsprioriterede områder, såsom innovation og økonomisk vækst. Ud fra en bredere betragtning burde reglerne i GDPR tillade en mere differentieret tilgang, hvor reglerne i højere grad tager hensyn til risiko, kontekst og proportionalitet, så privatlivsbeskyttelse, innovation, økonomisk vækst og digitalisering balanceres bedre.

GDPR betragtes som et centralt regelsæt i den regulatoriske ramme, der skal understøtte opnåelse af disse fastsatte målsætninger. Dette kan virke paradoksalt, idet databeskyttelsesreglerne samtidig stiller høje krav til brug af ny teknologi. Opnåelse af EU-Kommissionens digitale målsætninger udfordres dermed af de selvsamme regler i GDPR, som er tænkt som understøttelse af realiseringen af disse mål. Den teknologiske udvikling, som ses i samfundet i dag, defineres dermed af GDPR forstået på den måde, at digitaliseringen formes efter databeskyttelsesreglerne for at sikre en lovmedholdelig systemanvendelse, når brug af teknologi indebærer behandling af personoplysninger.

Retten til beskyttelse af personoplysningers potentielle bremsning af den teknologiske udvikling kan imidlertid betyde tab af menneskeliv på f.eks. sundhedsområdet, hvis livreddende teknologi ikke er mulig at anvende på grund af utilstrækkelig behandlingssikkerhed. Den retlige balance mellem brug af ny teknologi, f.eks. kunstig intelligens og cloud services, og de databeskyttelsesretlige regler bør således afklares nærmere af EU-Domstolen i samspil med de danske domstole, så GDPR ikke uhensigtsmæssigt bremser en teknologisk udvikling, der er gavnlig for fysiske personer.

Anbefalet videre læsning

Hanne Marie Motzfeldt, *Grundlæggende databeskyttelsesret*, Djøf Forlag 2022.

Christopher Kuner, Lee A. Bygrave & Christoffer Docksey, *The EU Data Protection Regulation (GDPR) – A commentary*, Oxford University Press 2020.

Indra Spiecker gen. Döhmman, Vagelis Papakonstantinou, Gerrit Hornung & Paul De Hert, *General Data Protection Regulation*, Bloomsbury Publishing 2023.

Henrik Udsen, "Databeskyttelsesret", I: Henrik Udsen, *Lærebog i informationsret*, Djøf Forlag 2022.

KAPITEL 5

EU og digital compliance

Charlotte Bagger Tranberg

1. Indledning

Formålet med dette kapitel er at give et overblik over udvalgte europæiske retsakter vedrørende det digitale område, som er blevet offentliggjort og vedtaget siden midten af 2022. Regelsættene er vedtaget i kølvandet på GDPR (skulle anvendes fra 25. maj 2018) og er en naturlig forlængelse af den digitale udvikling i samfundet. Dette kapitel beskriver ikke kravene i GDPR i detaljer, men henviser til kapitel 4, hvor det er relevant.

Kapitlet giver også eksempler på, hvordan kravene i lovgivningen virker på tværs af regelsættene og via operationelle processer transformeres ind i de organisationer, som er forpligtede til at efterleve dem, men også de udfordringer, som de omfattede organisationer står over for – både i forbindelse med implementering af reglerne og den løbende sikring af compliance med dem. Selvom det til tider kan virke som en opgave, der er uoverskuelig (grænsende til det umulige), kan det godt lade sig gøre at komme i mål med implementeringen og – ikke mindst – sikre løbende vedligeholdelse.

2. Historisk rids

Udvikling og brug af ny teknologi har betydning for lovgivningen, fordi udviklingen – og den derpå følgende brug – ikke altid kan rummes i den eksisterende lovgivning. Den stigende samling af oplysninger om borgere, medarbejdere og kunder i manuelle registre i midten af 1970'erne indebar, at Danmark som blot det andet land i verden (efter Sverige) vedtog love om offentlige myndigheders registre og om private registre (samlet: Registerlovene), som trådte i kraft 1. januar 1979.

I begyndelsen af 1990'erne begyndte EF – Det Europæiske Fællesskab, der med Maastricht-traktatens ikrafttrædelse den 1. november 1993 blev til Den